

RAPPORT MÉTHODOLOGIQUE D'ANALYSE DE RISQUES CYBER

1. Objectifs et Périmètre

L'objectif de cette démarche est d'identifier, d'analyser et de traiter les risques pesant sur les actifs critiques de l'organisation afin d'assurer la continuité des activités métiers, de garantir la conformité réglementaire (notamment le RGPD) et de protéger le patrimoine informationnel.

Le périmètre de l'analyse englobe :

- Les infrastructures techniques (systèmes ERP, serveurs d'archivage, portails clients, datacenters).
- Les terminaux mobiles et utilisateurs nomades (équipes commerciales).
- L'écosystème de l'organisation (prestataires externes, sous-traitants, interconnexions partenaires).

2. Démarche Méthodologique (Inspirée d'EBIOS RM / ISO 27005)

La démarche s'articule autour de quatre grandes phases itératives :

Phase 1 : Cadrage et Identification des Actifs Critiques

- **Objectif** : Identifier les fonctions métiers et les données indispensables à la survie de l'entreprise (ex: Données RH clients, système de planification de production ERP).
- **Évaluation des Événements Redoutés** : Déterminer les impacts maximaux acceptables en termes de Disponibilité, Intégrité, Confidentialité et Traçabilité (DICT).

Phase 2 : Analyse de l'Écosystème et des Sources de Risques

- **Objectif** : Identifier *qui* peut attaquer et *comment*.
- **Cartographie des Tiers** : Évaluation de la surface d'attaque étendue. Les prestataires externes et les maillons faibles de la *Supply Chain* sont intégrés comme des vecteurs de rebond prioritaires.
- **Modélisation des Menaces** : Définition du niveau de motivation et des capacités des attaquants (ex: Cybercriminalité organisée visant un gain financier).

Phase 3 : Construction des Scénarios de Risques

- **Scénarios Stratégiques** : Vision macroscopique du chemin d'attaque (ex: compromission d'un sous-traitant pour déployer un Ransomware).
- **Scénarios Opérationnels** : Déclinaison technique précise sous forme de chaîne d'attaque (*Kill Chain*) :
 1. **Reconnaissance** (Recherche de vulnérabilités ou de fuites de données).
 2. **Accès Initial** (Exploitation d'une faille web, vol d'identifiants, usurpation).
 3. **Découverte / Phase Latérale** (Exploration du réseau interne, ciblage des serveurs obsolètes).
 4. **Exploitation / Action sur l'objectif** (Chiffrement par ransomware, exfiltration de données).

Phase 4 : Évaluation et Traitement des Risques

Chaque scénario est évalué selon sa vraisemblance (probabilité d'occurrence) et sa gravité (impact financier, juridique ou réputationnel). Le choix de la stratégie de traitement s'appuie sur le principe d'**arbitrage technico-économique** :

- **RÉDUIRE (Mitigation)** : Implémentation de mesures de sécurité (techniques ou organisationnelles) pour diminuer la probabilité ou l'impact du risque au niveau le plus bas possible à un coût proportionné (ex: Chiffrement BitLocker, isolation réseau).
- **TRANSFERER (Transfer)** : Déplacement de la charge financière du risque vers un tiers (Assurance Cyber) pour faire face aux sinistres catastrophiques à faible probabilité.
- **ÉVITER (Avoidance)** : Suppression pure et simple de l'activité ou de l'actif obsolète qui génère le risque (ex: Décommissionnement d'un vieux portail web).
- **ACCEPTER (Acceptance)** : Décision managériale consciente de vivre avec le risque résiduel lorsque le coût de sa protection dépasse la valeur de l'actif ou lorsque le risque est hautement confiné (nécessite une validation formelle signée de la direction).

3. Principes Directeurs pour le Risk Manager

1. **Parler la langue du Business** : Traduire les vulnérabilités techniques (CVE, failles de code) en impacts financiers (perte de CA par jour, amendes réglementaires) pour éclairer les décisions du Comité de Direction.
2. **Pragmatisme Économique** : Chercher le "Risque Résiduel Acceptable" plutôt que la sécurité absolue. Privilégier les mesures transitoires à bas coût (mesures compensatoires) lorsque des projets de migration à long terme sont déjà budgétisés.
3. **Approche Zero Trust** : Considérer que la sécurité périmétrique interne est insuffisante. Intégrer le contrôle continu des accès logiques des tiers et la micro-segmentation des réseaux comme des piliers de la résilience cyber moderne.